

Penetration Test Remediation Summary

— 2026

Confidential. Evidence record demonstrating that issues identified in Normain's most recent penetration test have been addressed. Prepared in support of the Vanta control "*Penetration test remediation*" (ISO 27001:2022, SOC 2).

Test details

Asset / scope	app.normain.com — Web Application
Vendor	Cacilian / Prescient Security
Report date	2026-05-21
Assessment window	2026-05-11 – 2026-05-13
SOW#	SOW-35119758
Report approval (vendor)	Jason LeDuc, COO
Client POC	Sara Landfors (sara@normain.com)
Frameworks	ISO 27001:2022, SOC 2
Summary prepared	Kalle Hansson — 2026-06-20

Outcome

The 2026 assessment identified **2 findings** (no Critical or High). Both are now addressed: the Medium finding was remediated and verified by vendor retest; the Low finding was formally risk-accepted with management sign-off.

ID	Finding	Risk	Disposition	Tracking
M1	Domain-Based Role Assignment Without Email Verification (Role Enumeration)	Medium (CVSS 5.3)	Remediated — fixed & vendor-retested closed 2026-05-21	NOR-2731
L1	Content Security Policy Implemented in an Insecure Manner (style-src)	Low (CVSS N/A)	Risk accepted — dual management sign-off 2026-06-20	NOR-2858

ID	Finding	Risk	Disposition	Tracking
	'unsafe-inline')			

M1 — Domain-Based Role Assignment Without Email Verification

Finding. The application auto-assigned the elevated creditManager role to any signup using an @normain.com email address, without verifying email ownership — enabling pre-authentication privilege escalation / corporate-email impersonation. CWE-863; OWASP A01:2025 Broken Access Control.

Remediation. The creditManager auto-assignment for normain.com addresses was restricted to sign-ups that flow through a trusted social provider (verified email), preventing the role from being granted on unverified email sign-ups.

Verification. Vendor retest on 2026-05-21 confirmed the finding is **Closed** (see report, M1 retest evidence).

Tracking. Linear NOR-2731 (Done) — Cacilian ticket T39825.

L1 — CSP Implemented in an Insecure Manner

Finding. The Content Security Policy uses 'unsafe-inline' in style-src and style-src-attr. An attacker could embed obfuscated styles to manipulate page layout or hide/deceive UI elements. Report status: Open.

Disposition: Risk accepted for this assessment cycle. Rationale:

- Severity is Low (CVSS N/A).
- The weakness is confined to style-src / style-src-attr. script-src is locked to 'self' https://eu-assets.i.posthog.com with no 'unsafe-inline' (confirmed by live header capture 2026-06-21), so script injection is not enabled by this finding — impact is limited to CSS-based UI manipulation.
- Removing 'unsafe-inline' from styles requires refactoring inline styles across the application; deferred.
- To be revisited at the next annual penetration test.

Approval.

- Kalle Hansson, Manager — 2026-06-20
- Sara Landfors, CEO — 2026-06-20

Tracking. Linear NOR-2858.

Evidence references

All artifacts below are stored in this same Drive folder ("09 - Penetration Testing").

#	Evidence	Type	Demonstrates
1	Normain_Normain_WebApplication_Testing_Report_2026.pdf	Vendor report (PDF)	Findings + M1 vendor retest (closed)

#	Evidence	Type	Demonstrates
2	Penetration Test Remediation Summary 2026 (this document)	Google Doc	Management remediation summary & disposition
3	Pentest 2026 - M1 remediation (Linear NOR-2731).png	Screenshot	M1 remediation tracked & Done
4	Pentest 2026 - L1 risk acceptance signoff (Linear NOR-2858).png	Screenshot	L1 risk-acceptance + dual management sign-off
5	Pentest 2026 - Live security headers 2026-06-21.txt	Config capture	Current CSP / security-header state

Linear references: NOR-2731 — <https://linear.app/normain/issue/NOR-2731> | NOR-2858 — <https://linear.app/normain/issue/NOR-2858>